

0.1 Đặt vấn đề

Cuộc cách mạng chuyển đổi số hiện nay đang tác động mạnh mẽ đến mọi lĩnh vực của kinh tế - xã hội, và ngành tài chính ngân hàng cũng không nằm ngoài xu thế này. Trong những năm gần đây, xu hướng thanh toán không dùng tiền mặt cùng với sự phát triển của các dịch vụ tài chính số đã trở thành một xu hướng tất yếu mà không một ngân hàng nào muốn bị bỏ lại phía sau. Các dịch vụ như mobile banking, Apple Pay,... ngày càng phổ biến và dần trở thành một phần trong thói quen sinh hoạt hàng ngày của người dùng.

Trước bối cảnh đó, các ngân hàng lớn như MB, VCB, TCB... đã và đang đầu tư mạnh mẽ vào lĩnh vực công nghệ thông tin **saigontimes_ngan_hang_cong_nghe**. Các hệ thống core-banking (như Way4, T24) cùng với các hệ thống hỗ trợ khác liên tục được nâng cấp và mở rộng. Điều này dẫn đến sự gia tăng nhanh chóng về số lượng các ứng dụng và hệ thống nội bộ phục vụ cho quá trình phát triển và vận hành.

Song song với đó, quy mô nhân lực công nghệ thông tin trong các ngân hàng cũng ngày càng lớn **mb_nhan_luc_cntt**, kéo theo bài toán quản lý và phân quyền truy cập đối với các hệ thống trở nên phức tạp hơn. Mặc dù nhiều ngân hàng đã triển khai các hệ thống phân quyền tập trung, nhưng trên thực tế vẫn chưa giải quyết triệt để vấn đề, và trong nhiều trường hợp vẫn tồn tại các quy trình thủ công.

Chẳng hạn, khi một nhân viên được giao nhiệm vụ phát triển một chức năng mới và cần truy cập vào một số hệ thống liên quan nhưng chưa được cấp quyền, họ thường phải chủ động tìm kiếm thông tin liên hệ, trao đổi với các bộ phận liên quan để được cấp quyền. Quy trình này không chỉ mất thời gian mà còn làm giảm năng suất lao động, đồng thời tạo ra sự phụ thuộc vào các thao tác thủ công và tiềm ẩn rủi ro trong việc kiểm soát quyền truy cập.

Từ thực tế đó, có thể thấy rằng việc xây dựng một hướng tiếp cận hiệu quả hơn trong quản lý và phân quyền truy cập là cần thiết, nhằm nâng cao hiệu quả vận hành, giảm thiểu các thao tác thủ công và hướng tới một môi trường làm việc chuyên nghiệp, nhất quán hơn.

0.2 Mục tiêu và phạm vi đề tài

Hiện nay, bài toán quản lý danh tính và phân quyền truy cập đã được nghiên cứu và triển khai rộng rãi thông qua nhiều giải pháp khác nhau, từ các sản phẩm mã nguồn mở đến các sản phẩm thương mại. Một số giải pháp tiêu biểu có thể kể đến như Keycloak - nền tảng mã nguồn mở hỗ trợ xác thực và phân quyền tập trung khá phổ biến, hay các dịch vụ thương mại như Azure Active Directory (Entra ID) của

Microsoft, cung cấp các cơ chế xác thực hiện đại, hỗ trợ đăng nhập một lần (SSO) cũng như quản lý quyền theo vai trò.

Nhìn chung, các giải pháp trên đã giải quyết được nhu cầu quản lý và phân quyền tập trung, đồng thời đáp ứng các yêu cầu về bảo mật cho hệ thống. Tuy nhiên, trong thực tế triển khai tại các tổ chức có số lượng lớn các phần mềm nội bộ, đa dạng từ hệ thống tự phát triển đến các phần mềm thương mại do bên thứ ba cung cấp, vẫn còn tồn tại một số hạn chế. Đặc biệt, đối với các hệ thống sử dụng giao thức không đồng nhất, việc tích hợp thường đòi hỏi cấu hình phức tạp và trong một số trường hợp vẫn phải thực hiện các bước xác thực thủ công, rời rạc. Điều này dẫn đến những rủi ro về bảo mật trong quá trình vận hành, đồng thời ảnh hưởng đến hiệu suất làm việc của nhân viên cũng như hiệu quả vận hành của tổ chức.

Từ những hạn chế trên, có thể nhận thấy rằng các giải pháp hiện tại vẫn chưa hoàn toàn đáp ứng được nhu cầu quản lý tập trung theo hướng tự động và linh hoạt cho toàn bộ hệ thống. Do đó, đề tài này hướng tới việc xây dựng một hệ thống quản lý danh tính và phân quyền truy cập tập trung, nhằm khắc phục các hạn chế nêu trên, đặc biệt trong việc tích hợp đa dạng hệ thống và giảm thiểu các thao tác thủ công.

Trong phạm vi của đề tài, bài toán được mô phỏng thông qua ứng dụng quản lý thay đổi và go-live nội bộ (Change & Go-Live Management) — một hệ thống được phát triển riêng, đại diện cho các phần mềm ứng dụng nghiệp vụ trong ngân hàng đòi hỏi kiểm soát quyền truy cập chặt chẽ theo vai trò và vị trí công tác. Hệ thống đề xuất hướng tới khả năng quản lý và phân quyền truy cập thống nhất, từ đó nâng cao hiệu quả quản lý, giảm thiểu các thao tác thủ công và tăng tính nhất quán trong toàn bộ hệ thống. Chi tiết về ứng dụng minh họa được trình bày tại Phụ lục ??.

0.3 Định hướng giải pháp

Từ việc xác định các vấn đề tại Mục 0.2, đề tài định hướng xây dựng một giải pháp xác thực và phân quyền truy cập tập trung, dựa trên mô hình phân quyền chủ đạo là RBAC (Role-Based Access Control), kết hợp với quy trình phê duyệt (approval workflow) nhằm đảm bảo việc cấp quyền linh hoạt, chủ động nhưng vẫn đáp ứng các yêu cầu kiểm soát chặt chẽ. Về các chuẩn xác thực và ủy quyền, hệ thống sử dụng OAuth2 kết hợp với OpenID Connect (OIDC) để cung cấp cơ chế xác thực tập trung và hỗ trợ đăng nhập một lần. Về mặt kiến trúc, mô hình microservices kết hợp hướng sự kiện (event-driven) được áp dụng nhằm nâng cao khả năng mở rộng và tách biệt các chức năng trong hệ thống.

Dựa trên các định hướng trên, đề tài xây dựng một hệ thống quản lý danh tính và phân quyền truy cập tập trung (IAM), cho phép quản lý toàn bộ vòng đời truy

cấp của người dùng, từ khi gia nhập, thay đổi vị trí công tác cho đến khi rời khỏi tổ chức. Hệ thống hướng tới việc tự động hóa quá trình cấp phát và thu hồi quyền, đồng thời hỗ trợ tích hợp thống nhất giữa các ứng dụng nội bộ và các phần mềm bên ngoài.

Đóng góp chính của đề tài bao gồm việc đề xuất và triển khai một mô hình IAM tập trung, kết hợp giữa phân quyền theo vai trò và cơ chế phê duyệt, đồng thời tự động hóa vòng đời quyền truy cập gắn liền với vòng đời nhân sự. Kết quả đạt được là một hệ thống hoàn chỉnh được kiểm chứng thông qua ứng dụng nghiệp vụ nội bộ, góp phần nâng cao hiệu quả quản lý truy cập và giảm thiểu các thao tác thủ công trong tổ chức.

0.4 Bố cục đồ án

Phần còn lại của báo cáo đồ án tốt nghiệp này được tổ chức thành năm chương như sau.

Chương 2 trình bày kết quả khảo sát và phân tích yêu cầu hệ thống. Chương này xác định các tác nhân, mô tả quy trình nghiệp vụ thông qua biểu đồ hoạt động, đặc tả chi tiết sáu use case quan trọng nhất, và trình bày các yêu cầu phi chức năng liên quan đến độ tin cậy, bảo mật, khả năng mở rộng và tiêu chuẩn công nghệ.

Chương 3 giới thiệu các công nghệ và nền tảng lý thuyết được áp dụng trong đề tài. Nội dung tập trung vào mô hình phân quyền RBAC, các chuẩn xác thực và ủy quyền OAuth2, OpenID Connect và PKCE, cơ chế JWT, cùng với các công nghệ triển khai gồm Java Spring Boot, Oracle Database và Apache Kafka.

Chương 4 trình bày thiết kế và kết quả xây dựng hệ thống. Chương này bao gồm thiết kế kiến trúc microservices kết hợp hướng sự kiện, thiết kế giao diện người dùng, thiết kế lớp và cơ sở dữ liệu, danh sách thư viện và công cụ sử dụng, kết quả xây dựng từng thành phần, minh họa các chức năng chính, kết quả kiểm thử và quy trình triển khai bằng Docker.

Chương 5 trình bày các đóng góp kỹ thuật cốt lõi của đề tài. Cụ thể, chương này phân tích mô hình RBAC mở rộng theo chiều vị trí công tác, cơ chế tự động hóa vòng đời quyền thông qua sự kiện Kafka, giải pháp thu hồi quyền tức thì không phụ thuộc thời gian hết hạn token, và minh chứng kiểm chứng toàn bộ giải pháp thông qua ứng dụng quản lý thay đổi nội bộ.

Chương 6 tổng kết các kết quả đạt được, đối chiếu với các giải pháp thương mại hiện có, nhận định các hạn chế còn tồn tại và đề xuất ba hướng phát triển tiếp theo bao gồm tích hợp LDAP gateway, mở rộng engine xác thực đa yếu tố, và hoàn thiện pipeline CI/CD hướng đến triển khai quy mô thực tế.